Actividad 10 — Crear una política mínima de protección de claves

Define una política de entre 5 y 10 reglas para la gestión de claves criptográficas.

Debe considerar como mínimo:

- generación
- almacenamiento
- acceso
- rotación
- respaldo
- revocación
- exposición accidental
- eliminación

Política de protección de claves criptográficas

- **Generación:** Las claves criptográficas deben generarse mediante herramientas y algoritmos seguros, utilizando valores aleatorios adecuados. No se deben utilizar claves fáciles de adivinar.
- **Almacenamiento:** Las claves deben almacenarse en un sistema seguro de gestión de secretos o claves, separado de la base de datos y del código fuente.
- **Acceso:** Únicamente el personal autorizado debe tener acceso a las claves, aplicando el principio de mínimo privilegio.
- **Rotación:** Las claves deben cambiarse periódicamente de acuerdo con las políticas de la organización y cuando exista sospecha de que fueron comprometidas.
- **Respaldo:** Deben existir respaldos seguros de las claves cuando sean necesarios para recuperar información cifrada. Estos respaldos deben estar cifrados y tener acceso restringido.
- **Revocación:** Cuando una clave se encuentre comprometida o deje de ser necesaria, debe revocarse o deshabilitarse para impedir su uso no autorizado.
- **Exposición accidental:** Si una clave se publica accidentalmente en GitLab, un archivo SQL o cualquier otro medio no autorizado, debe considerarse comprometida. Se debe revocar o reemplazar y evaluar qué información pudo quedar expuesta.
- **Eliminación:** Las claves que ya no sean necesarias deben eliminarse de forma segura, verificando que no permanezcan en archivos temporales, copias innecesarias o ubicaciones accesibles.

Análisis

Estas reglas ayudan a mantener la confidencialidad y disponibilidad de la información protegida mediante cifrado. La seguridad no depende únicamente del algoritmo utilizado, sino también de cómo se generan, almacenan, distribuyen y administran las claves.

Conclusión

Una gestión adecuada de las claves criptográficas reduce el riesgo de acceso no autorizado y pérdida de información. Por ello, las claves reales nunca deben incluirse directamente en scripts SQL ni publicarse en repositorios GitLab, incluso si son privados.